

Project 5: Turning a Risk Assessment into a Risk Mitigation Plan

Cole Dombrowski - MISY 5325

1. Risk Assessment Carryforward

Risk	Asset / Business Function	Threat & Vulnerability	Likelihood	Impact	Overall Risk
Risk 1 (R1)	Electronic Health Records (EHR)	Threat: Ransomware Vulnerability: Unpatched servers, flat network	High	Very High	Critical
Risk 2 (R2)	Remote Access & Email	Threat: Phishing/credential theft. Vulnerability: No universal MFA	High	High	High
Risk 3 (R3)	Medical IoT Devices	Threat: Malicious lateral movement Vulnerability: Legacy firmware, lack of network isolation	Moderate	Very High	High
Risk 4 (R4)	Vendor Portals	Threat: Third-party breach Vulnerability: Over-permissive vendor access	Moderate	High	High
Risk 5 (R5)	Patient Records (ePHI)	Threat: Insider snooping Vulnerability: Weak audit reviews	Moderate	Moderate	Moderate

2. Risk Treatment Decisions

Risk	Treatment Decision	Reason for Decision
R1: Ransomware	Mitigate	This is a Critical risk threatening acute patient safety and enterprise viability; active technical mitigation is mandatory to sustain healthcare operations

R2: Credential Theft	Mitigate	Compromised credentials are the primary entry point for ransomware and data breaches, requiring immediate treatment
R3: Medical IoT	Mitigate	Legacy devices cannot be patched or replaced cheaply; network isolation is required to protect life safety
R4: Vendor Access	Transfer	Financial liability must be transferred via cyber-insurance clauses in Business Associate Agreements (BAAs), supported by low-cost procedural controls
R5: Insider Misuse	Accept	SCHN will temporarily accept the risk because its limited resources are being directed toward the three higher-priority initiatives. Existing manual audits will remain in place

3. Recommended Controls and Mitigation Actions

Universal Multi-Factor Authentication (MFA)

- **Risk Addressed:** R2 & R1
- **Recommended Control:** Enforce phishing-resistant MFA on all remote connections, VPNs, and external webmail (NIST SP 800-53 IA-2)
- **Control Class:** Technical
- **Reduction Mechanism:** Reduces likelihood by reducing the chance that stolen passwords can be used to gain unauthorized access
- **Responsibility:** Information Security Officer (ISO)
- **Effort / Impact:** Medium effort / Low operational impact (internal workstations remain unimpeded)

Immutable Cloud Backups

- **Risk Addressed:** R1
- **Recommended Control:** Deploy write-once-read-many (WORM) immutable backups air-gapped from the primary network (NIST SP 800-53 CP-9)
- **Control Class:** Technical and Physical

- **Reduction Mechanism:** Reduces **impact** by guaranteeing EHR restoration without paying extortion
- **Responsibility:** IT Systems Administration
- **Effort / Impact:** **Medium** effort / **Low** operational impact (runs off-hours)

Medical IoT Network Segmentation

- **Risk Addressed:** R3 & R1
- **Recommended Control:** Isolate medical devices onto dedicated VLANs restricted by strict firewall rules (NIST SP 800-53 AC-4)
- **Control Class:** Technical and Administrative
- **Reduction Mechanism:** Reduces **likelihood and impact** by quarantining vulnerable unpatchable devices
- **Responsibility:** Network & Clinical Engineering
- **Effort / Impact:** **High** effort / **Medium** operational impact

Vendor Governance & BAA Updates

- **Risk Addressed:** R4
- **Recommended Control:** Mandate strict session timeouts for vendors and update BAAs to require third-party cyber-insurance indemnification (NIST SP 800-53 PS-7)
- **Control Class:** Administrative
- **Reduction Mechanism:** Reduces **likelihood** (via access control) and transfers financial **impact**
- **Responsibility:** Compliance Officer
- **Effort / Impact:** **Low** effort / **Low** operational impact

4. Mitigation Priorities and Implementation Plan

Priority	Initiative	Dependencies & Barriers	Risks Addressed	Responsible	Timeline & Justification	Operational Effect
1	Universal MFA	User enrollment and compatibility with existing remote-access systems	R1, R2	ISO	Immediate (0-30 days). Instantly closes the primary gateway for external attackers, representing the most urgent plan of action	Low disruption to internal clinical workflows
2	Immutable Backups	Backup configuration, storage setup, and recovery testing	R1	IT Admin	Near Term (31-90 days). Guarantees business continuity against cyber extortion and physical disasters	Low; primarily IT implementation work
3	Medical IoT VLANs	Device compatibility and coordination with Clinical Engineering	R1, R3	Network	Intermediate (3-6 months). Protects life-safety devices from internal lateral threats	Medium; may require planned maintenance

5. Organizational Tradeoffs

Security Rigor vs. Clinical Usability: Implementing MFA everywhere slows down emergency room physicians. *Tradeoff Decision:* SCHN will apply MFA exclusively to remote, external access while maintaining fast proximity-badge logins for internal clinical workstations to prioritize patient care.

Network Segmentation vs. Device Replacement: Replacing legacy biomedical devices eliminates firmware flaws but requires unachievable capital budgeting. *Tradeoff Decision:* Network VLAN segmentation serves as a highly effective compensating control, isolating the threat at a fraction of the hardware replacement cost.

6. Residual Risk

Risk	Original Risk	Treatment	Expected Residual Risk	Justification
R1	Critical	Mitigate	Low/Moderate	Immutable backups guarantee data recovery despite targeted attacks, bringing the risk to an acceptable level
R2	High	Mitigate	Low	MFA blocks access even if passwords are stolen
R3	High	Mitigate	Moderate	Underlying device flaws remain but VLANs prevent exploitation
R4	High	Transfer	Moderate	Financial liability is transferred to vendors via BAAs
R5	Moderate	Accept	Moderate	Accepted to prioritize funds; manual audits provide baseline deterrence

7. Management Recommendation

Sabine Coastal Health Network leadership should approve Priority 1 (Universal MFA) within the next 30 days to reduce unauthorized external access. Following this, leadership should fund Immutable Backups and Medical IoT Network Segmentation to complete the three planned initiatives for the year. This approach addresses SCHN's most critical risks, especially ransomware and patient safety, while staying within financial limits and avoiding major disruptions to clinical workflows. Where lower-priority risks, such as insider access and vendor liability, can continue to be addressed through existing policies and contracts.

References

- Gibson, D., & Igonor, A. (2020). *Managing risk in information systems* (3rd ed.). Jones & Bartlett Learning.
- National Institute of Standards and Technology. (2012). *Guide for conducting risk assessments* (NIST Special Publication 800-30, Revision 1). U.S. Department of Commerce.
- National Institute of Standards and Technology. (2020). *Security and privacy controls for information systems and organizations* (NIST Special Publication 800-53, Revision 5). U.S. Department of Commerce.